

14. АНАЛИЗ ЭКСПЛУАТАЦИИ ПРОЕКТА

14.1. Disaster Recovery

Disaster Recovery (DR) — катастрофоустойчивость или аварийное восстановление, инструмент реагирования на критические сбои в ИТ-инфраструктуре компании, направленный на быстрое восстановление работы всех систем. То есть отказ серверной или даже всего ЦОДа не должен надолго (в отдельных случаях речь о секундах) прерывать бизнес-процессы.

Реализация DR основана на управлении рисками (анализ, оценка, нужен ли вообще план восстановления, планирование). Один из вариантов — дублирующая инфраструктура, способная взять на себя всю нагрузку, если основная система откажет. В идеале ключевые узлы инфраструктуры должны работать по принципу георезервирования:

- *георезерв инфраструктуры* — запасную инфраструктуру разворачивают в другой геолокации, не подверженной или менее подверженной аналогичным природным или техногенным ЧС. Да, от взрыва Солнца даже ЦОД на Марсе не спасёт, но уберечься от наводнения, развернув дублирующую инфраструктуру в разных городах, получится;
- *георезерв электросети* — зачастую используют другие магистральные каналы. Например, выходит из строя местная электростанция, основной ЦОД переходит на дизельные генераторы, а запасной ЦОД продолжит питаться от ГЭС. Так как второй вариант дешевле, можно остановить работу первого ЦОДа, пока аварийные службы восстанавливают электропитание. Такой подход также используют и в рамках одного ЦОДа;
- *георезерв интернет-каналов* — другие магистральные интернет-провайдеры, каналы которых не проходят в одном месте. Если экскаватор пробьет один из каналов, когда будет копать рядом с ЦОДом, это не остановит работу.

14.2. Disaster Recovery Plan

Всем без исключения нужен план аварийного восстановления **DRP (Disaster Recovery Plan)**. Его составлением нужно заниматься комплексно: со стороны бизнеса и со стороны ИТ-инфраструктуры и специалистов. Даже малому бизнесу с одним сервером неплохо бы иметь план на салфетке, что делать, когда тот выйдет из строя, чтобы минимизировать финансовые потери.

Пункты, которые нужно проработать при составлении DRP:

- состав штатной DR-команды и уровни доступа у сотрудников;
- предварительная оценка рисков;
- определение критически важных бизнес-процессов и данных;
- бюджет;
- необходимость в подрядчиках и поставщиках (услуг в том числе), а также их надежность;
- используемые технологии;
- необходимые уровни доступности;
- нужен ли SLA (Service-Level Agreement);
- быстрое восстановление или параллельная инфраструктура.

1. Состав штатной DR-команды.

Во-первых, кто-то должен спланировать, утвердить, реализовать и обслуживать инфраструктуру DR. Во-вторых, должен быть регламент конкретных действий каждого сотрудника, чтобы как можно быстрее начать процедуру аварийного восстановления. Полностью автоматизировать весь процесс невозможно, поэтому нужно выделить и/или нанять сотрудников под эти задачи. Если компания и инфраструктура небольшая, то хватит одного человека, если речь о дата-центрах Amazon, то нужна целая команда или департамент.

При этом нужно чётко определить необходимые уровни доступа для каждого специалиста, чтобы не случилось сюрпризов, когда у члена DR-команды нет доступа к северу или ЦОДу. Или, наоборот, когда новый член команды будет иметь слишком много прав.

2. Предварительная оценка рисков.

Оценку рисков можно провести самостоятельно — силами штатных сотрудников, исходя из собственного опыта. Или можно отдать эту задачу на аутсорс. Методик много, универсальной модели не существует, но есть общие фундаментальные принципы, от которых нужно отталкиваться.

Внешние риски

Этот вид рисков требует особого внимания и анализа, так как включает в себя политическую, экономическую, экологическую и другие повестки. Всё — от наводнения до тестирования автономного рунета и санкций — может повлиять на ваши бизнес-процессы.

Другие риски

Обстоятельства непреодолимой силы не получится противостоять, но вы сможете подготовиться к ним. К счастью, некоторые риски уже проанализированы и оценены. Нужно только правильно воспользоваться

общедоступной информацией.

Внутренние риски

С определением внутренних рисков ситуация обстоит одновременно проще и сложнее, так как они напрямую связаны с деятельностью компании. С одной стороны — ими легче управлять и легче предвидеть, а с другой — их может быть значительно больше, а чтобы провести точный анализ, нужно много данных и времени. Например:

Риски человеческого фактора.

Невозможно на 100% процентов быть уверенным в ком-то. Человек может недобросовестно работать, устать, допустить ошибку, обидеться, внезапно уволиться, заболеть, взять отгул по семейным обстоятельствам, переоценить/недооценить свои возможности и т.д. Поэтому человеческий фактор всегда стоит закладывать в оценку рисков. Это не значит, что у вас будут точные цифры. Скорее вы будете готовы к тому, что даже бульдозер могут перевернуть на ровном месте, а значит было бы неплохо иметь второй.

Технические риски.

Если составить технические регламенты для сотрудников и строго следовать им, то можно минимизировать риск ошибок. Однако всё равно остаётся вероятность, что ошибку допустят на этапе написания инструкции, или сотрудник, читающий её, что-то не так поймёт. Это может быть опасно как для оборудования, так и для сотрудников. Поэтому нужно со вниманием отнестись к соблюдению регламентов, инструкций, техники безопасности и т.д., а также учесть, что и они могут быть не идеальны и требуют доработок со временем.

Технологические риски.

Технологические риски связаны с типом используемого оборудования, ПО, интенсивностью нагрузок т.д. Стоит учесть, что продукция крупных вендоров-пионеров заслуживает бóльшего доверия: она проверена временем, оснащена проприетарными разработками, да и технологии тестирования и производства более совершенны, так как на отладку всех процессов ушли десятилетия.

Оценивание внутренних рисков

Вряд ли вам удастся с точностью до процента определить, какова вероятность возникновения человеческого фактора; насколько сервер Dell или HPE будет отличаться надежностью от серверов Atos, NEC или Supermicro; как часто выходит из строя оборудование, обслуживаемое по регламенту и без. Разве что вы целенаправленно не собирали статистику лет 5-10 по всем направлениям.

В противном случае вы можете поискать общедоступную информацию в смежных или аналогичных областях, а все точки отказа, которые кажутся

наиболее уязвимыми, защитить. Что касается ИТ-инфраструктуры, Disaster Recovery закрывает множество вопросов — спокойный сон в их числе.

3. Определите критически важные бизнес-процессы и уровень доступности для них.

Чтобы ИТ-инфраструктура не стоила чудовищных денег, нужно расставить приоритеты. Если взять критерий непрерывной работы, то бизнес-процессам можно присвоить уровни важности: высокий, средний или низкий:

- *высокий*. Даже несколько минут простоя могут привести к большим и(или) необратимым потерям и негативным последствиям.
- *средний*. Бизнесу требуется быстрое восстановление, но он может пережить простой от нескольких минут до часа без существенных потерь.
- *низкий*. Это могут быть любые компании, которым больше важна сохранность данных, чем их непрерывная доступность. Простой от двух до нескольких часов не станет большой проблемой.

Когда вы закончите с приоритетностью бизнес-процессов, можно приступить к определению уровня доступности системы:

- *постоянная доступность (continuous availability)*. Если речь, например, об электронном движении капитала, то инфраструктура должна быть готова к запланированным и незапланированным простоям, а также непрерывно работать 24/7 годами.
- *непрерывный режим работы (continuous operations)*. Чуть менее доступная инфраструктура, не готовая к авариям на всех узлах, но по-прежнему работающая 24/7 годами, если не возникает сбоев.
- *высокая доступность (high availability)*. Режим работы инфраструктуры, при котором система периодически останавливается в нерабочие дни или на запланированное обслуживание с предварительным уведомлением пользователей. Режим работы определяется работой организации: 8/5, 8/7, 12/5, 12/7 и т.д.
- *обычная доступность*. Если высокой доступности и(или) сохранности данных не требуется, ИТ-системам присваивают статус Office Production. Инфраструктура этого уровня может не резервироваться или резервироваться на самых простых уровнях под конкретные задачи. Время восстановления от одного до нескольких дней.

4. Заключите SLA — соглашение об уровне обслуживания.

SLA (Service-Level Agreement) — это единый документ, договор между поставщиком и клиентом, в котором закрепляются конкретные услуги и их объем, ожидания сторон, их обязанности, точки контактов для решения проблем, метрики эффективности, а также время исправления инцидента (Время реакции на аварию + Время решения проблемы = Время исправления инцидента).

5. Определите RPO и RTO.

Важными параметрами аварийного восстановления являются RPO (Recovery Point Objective) и RTO (Recovery Time Objective). Требования по ним идут от бизнеса — директоров, руководителей и менеджеров, а IT-команда пытается максимально приблизиться к требуемым показателям, учитывая бюджет и реальное положение дел:

1. *RPO* — это целевая точка восстановления, которая устанавливается после определения точки безубыточности: затраты на сохранность актуальных данных не должны превышать ущерба от их потери. Если RPO равен 1-ой минуте, значит резервная копия будет обновляться каждую минуту. При этом копия будет только одна.
2. *RTO* — это целевое время восстановления. Устанавливается, чтобы понимать, за какой отрезок времени бизнес-процесс должен вернуться к полноценной работе. Если RTO установили в полчаса, значит через 30 минут система должна работать в штатном режиме — ни минутой позже.

6. Выбор конкретного решения DR.

Все предыдущие оценки позволят вам определиться, какой уровень DR подойдет под конкретный бизнес-процесс и бюджет.

1) бэкапы и быстрое восстановление из облака (DRaaS Backup & Restore).

Это компромиссный и относительно недорогой вариант, поскольку не приходится покупать, настраивать и обслуживать дублирующую инфраструктуру; стоимость такого решения минимальна, а платить нужно только за объем данных в облаке и за временное использование виртуальных машин в случае ЧС. Быстрое восстановление допускает непродолжительную остановку бизнес-процессов.

Существуют готовые решения DR в облаке:

1. Veeam Disaster Recovery Orchestrator;
2. Mail.ru Cloud DRaaS;
3. CloudMTS Disaster Recovery;
4. Множество других DRaaS сервисов.

2) *параллельная инфраструктура (Multi-Site Solution).*

Параллельно основной будет подготовлена резервная инфраструктура с репликой системы. Преднастроенные WAN-каналы, сеть и виртуальные машины со всем необходимым софтом будут ожидать своего часа.

Аналогично первому пункту можно организовать всё в облаке, но тогда стоит посчитать: в какие затраты это выльется за несколько лет. Возможно, в перспективе 5-10 лет на аренду вы потратите соизмеримую с покупкой и обслуживанием сумму, но владеть ничем не будете. Параллельная инфраструктура позволяет восстановиться очень быстро — от пары секунд до нескольких минут.

7. *Проверка работоспособности: учения и тесты failover.*

Будет обидно, если вы заранее побеспокоитесь об аварийном восстановлении, но система не запустится в критической ситуации, так как никто не проводил тесты. И важно учесть, что единоразовым начальным тестированием тут не отделаешься. Сформированная ответственная группа должна постоянно проводить учения и поддерживать актуальное состояние DR-системы, чтобы соответствовать меняющимся внешним и внутренним рискам.

Учения чаще всего проводят отдельно для каждого риска. Например, DR-команда отключает сетевой кабель и тестирует падение интернет-провайдера. Другой сценарий — оценивают влияние человеческого фактора, когда сисадмин пропал (не вышел на работу, не вернулся с обеда). Аналогично проводят и учения по ИБ (информационной безопасности), имитируя различные кибератаки и вмешательства.

14.3. Риск = Угроза + Уязвимость + Актив

Риск:

1. *Угроза* — что-то плохое.
2. *Уязвимость* — особенность актива.
3. *Актив* — любой объект.

Если совсем уж перефразировать, то можно сказать, что риск это когда что то плохое происходит из за какой то особенности чего то.

При таком расщеплении на атомы все становится на свои места, ясна связь между угрозами и рисками безопасности.

Угроза просто описывает нам что-то плохое, в то время как *Риск* еще сообщает из-за чего это плохое может произойти.

Несколько примеров рисков, сформулированных по такой конструкции:

Раскрытие ключей (паролей) доступа из-за возможности атаки SMB Relay в ОС Windows

В данном случае:

1. *Угроза* – Раскрытие ключей (паролей) доступа.
2. *Уязвимость* – Возможности атаки SMB Relay.
3. *Актив* – ОС Windows.

Боковое перемещение злоумышленника по локальной сети из-за возможности удаленного подключения через RDS Shadow в ОС Windows

Закрепление злоумышленника в ОС из-за возможности распространения скриптов через Network Logon Scripts в доменных службах Active Directory

Заражение вредоносным программным обеспечением из-за реагирования на мошеннические, фишинговые письма работником // В качестве актива выступает человек

Неработоспособность серверного оборудования из-за нарушения температурного режима в серверном помещении // классический ИТ риск на доступность активов

Недоступность ИТ/ИБ персонала из-за отсутствия квалифицированной кадровой политики в компании // Это тоже не про ИБ, скорее про кадровые и управленческие риски компании, но влияет на функционирование системы информационной безопасности. Активом выступает компания как юридическое лицо.

14.3.1. Технологические угрозы

Какие бывают технологические угрозы, например:

- отказы аппаратного и технического обеспечения (от вычислительной техники до электроэнергии);
- отказы информационного обеспечения (внешние БД, информационное обеспечение);
- ошибки в математическом и программном обеспечении (ошибки при реализации алгоритма, при развертывании новой версии софта программа перестала запускаться на старых устройствах).

14.3.2. Реагирование на риски

Архитектурные изменения – рефакторинг, выделение отдельных компонентов, проведение работ, направленных на улучшение масштабируемости, переносимости, целостности данных (MVC паттерн).

Технические изменения – привлечение сервисных провайдеров, использование готовых фреймворков и библиотек, с прогнозируемым уровнем надежности.

Организационные изменения – применение технических средств

направленных на автоматизацию ЖЦ нашего продукта или системы (код в гите, ci/cd конвейер, виртуализация, мониторинг); переход на методологию разработки наиболее эффективную в предметной области проекта на основе оценки качества продукта при помощи треугольника управления проектом – “объем работы-время-ресурсы(деньги)” (рис. 14.1).



Рисунок 14.1. Треугольник управления проектом

14.4. Задание

1. Выбрать 3 технологические угрозы и оценить их влияние на функционал из матрицы требований.

(влияние оценить по 5-ти бальной шкале:

0 - не влияет,

1 - влияет незначительно,

2 - функциональность сохраняется, но снижается ее быстроедействие, 3 - функциональность доступна только в определенные интервалы времени,

4 - функциональность частично недоступна,

5 - функциональность недоступна полностью)

2. Преобразовать технологические угрозы в риски, оценив вероятность их возникновения при эксплуатации данного проекта.

3. Предложить для каждого риска свой метод обработки:

Снижение риска, с обоснованием за счет каких изменений будет

организовываться снижение риска (архитектурных, технических и организационных изменений).

Принятие риска, с обоснованием нецелесообразности мероприятий по его снижению.

Отказ от риска, с обоснованием изменений (отказываемся от рискованного проекта или от рискованного функционала).

Передача риска, с обоснованием изменений и оценкой их возможности (привлечение третьей стороны (провайдер облака или сервиса) с разделением зон ответственности и заключением SLA).